

MKS ERP — Security Posture Overview

1. FRAMEWORK & TECH STACK (INDUSTRY STANDARD)

BACKEND	FastAPI (Python) — dipakai Netflix, Uber, Microsoft, Cisco
FRONTEND	React 19 — dipakai Facebook, Airbnb, Instagram, Discord
DATABASE	MongoDB (NoSQL) — dipakai Adobe, Bosch, Toyota
AUTH	JWT + Cookie Session — RFC 7519 standard
PASSWORD HASH	bcrypt (12 rounds) — OWASP recommended
PDF ENGINE	PyMuPDF — dipakai Fortune 500 enterprise
WEB SERVER	Uvicorn ASGI — industry high-performance
DEPLOYMENT	Docker-ready + supervisord (production standard)

COMPLIANCE COVERAGE (OWASP Top 10 — 2021)

A01 Broken Access Control	role-based ACL + endpoint guards	✓ OK
A02 Cryptographic Failures	bcrypt, HTTPS, HTTP-only cookies	✓ OK
A03 Injection (SQL/NoSQL)	Motor async ORM (parameterized)	✓ OK
A04 Insecure Design	4-layer approval + audit trail	✓ OK
A05 Security Misconfig	security headers middleware	✓ OK
A07 Auth Failures	rate limit + policy + lockout	✓ OK
A09 Logging & Monitoring	activity_logs collection	✓ OK

2. SECURITY CONTROLS (LIVE IN SYSTEM)

PASSWORD POLICY	Min 10 karakter + huruf besar + angka + block default password
BRUTE FORCE	5x salah = akun locked 15 menit (per username, MongoDB counter)
FORCE CHANGE DEFAULT	User login pakai admin123/riski123 wajib ganti sebelum akses
IDLE AUTO-LOGOUT	Session expire 30 menit idle + warning 5 menit sebelum
SESSION COOKIE	httpOnly + SameSite=Lax + Secure (production HTTPS)
PASSWORD HASH	bcrypt 12 rounds — resistant to GPU brute force
XSS PROTECTION	React auto-escape + Content-Security via headers
CLICKJACKING	X-Frame-Options: SAMEORIGIN header
MIME SNIFFING	X-Content-Type-Options: nosniff header
HTTPS ENFORCE	Strict-Transport-Security (HSTS) 1 tahun
REFERRER LEAK	Referrer-Policy: strict-origin-when-cross-origin
CAMERA/MIC BLOCK	Permissions-Policy: deny all
DIGITAL SIGNATURE	PNG upload · placed per approver · immutable
AUDIT TRAIL	Setiap login/edit/approve/delete tersimpan permanent
ROLE-BASED ACCESS	9 role: admin, super_admin, eng_head, eng_staff, qc, sales, doc_control, purchasing, store
DATA OWNERSHIP	100% on-premise MongoDB — data tidak keluar LAN

3. RECOMMENDED HARDENING FOR ON-PREMISE DEPLOYMENT

- Nginx reverse proxy (block direct FastAPI port 8001 & MongoDB 27017 from LAN)
- HTTPS via self-signed cert or internal CA (Let's Encrypt for internal domain)
- Firewall: expose only port 443 · enable MongoDB auth (username/password in .env)
- Daily automated backup to separate drive/NAS (script provided) · monthly restore test
- Rotate JWT_SECRET quarterly · review audit logs weekly · patch OS/deps monthly